

PROJEKT ENGINEERING

Risikobehandlung

Herwig Mayr

Fakultät für Informatik, Kommunikation und Medien
Fachhochschule OÖ, Hagenberg



Risiko ?
...oder
bereits
Problem ?

Risikobegriff (I)

Risiko = Auswirkungen von Unsicherheiten auf die Ziele eines Systems
[ISO 31000:2018]



In Österreich (ugs.): Risiko = *negative* Auswirkungen von Unsicherheiten auf die Ziele (positive Auswirkungen = „Chance“!).

Aber per 1.1.2021 ÖNORM D 4900 an ISO 31000 angeglichen!



Risikobegriff (II)

Gefahr (in Ö/D/CH „Risiko“) = Möglichkeit eines zukünftigen Verlusts oder Schadens (ein potenzielles Problem)

Problem = eingetretene Gefahr

vorhersehbares Problem = unausweichliche negative zukünftige Konsequenz

Chance = Möglichkeit, Erwartungen (an das System) zu übertreffen



Beispiel/Übung: Risiken – Chancen und Gefahren im LEGO-Projekt

Chancen :

Gefahren:



Risikobehandlung

Risikobehandlung – Definition

Risikobehandlung = proaktive Berücksichtigung wahrscheinlicher Probleme
"Softwareentwicklung ohne Überraschungen" → reife Projektorganisation

Situierung der Risikobehandlung in der Projektentwicklung

- Risikobehandlung ist proaktiv.
- Auch viele Techniken der Projektentwicklung reduzieren das Projektrisiko, aber reaktiv.

Unterscheide:

- allgemeine Risiken
- projektspezifische Risiken

-> Risikobehandlung *nur für projektspezifische* Risiken



Risikobehandlung Ziel

Risikobehandlung - Ziel

- vorab Überlegen der Reaktionen auf potenzielle Probleme inkl. Treffen der vorbereitenden Maßnahmen
- Abwägen von Gefahren und Chancen; Eingehen der Risiken mit bestem Chancenpotenzial
- quantitatives Bewerten der Risiken zur Auswahl der für die Behandlung sinnvollsten



Ziel – Die Notwendigkeit von Risiken

Existierende Produktionsmittel erreichen bessere wirtschaftliche Performanz nur durch größere Unsicherheit, i.e. größeres Risiko.

[Gesetz von Böhm-Bawerk, zit. in „Principles of Software Engineering Management“, T. Gilb]

Risiken sind oft **wirtschaftliche Chancen**, daher **die richtigen** auf sich nehmen!

[„Management“, P. Drucker]



Ein erfolgreiches Projekt behandelt – die richtigen! – Risiken erfolgreich.

Risikoprofil = Summe der Einzelrisiken eines Projektes

Ziel – Bestimmung des Risikofaktors

Risikoeigenschaften:

- Wahrscheinlichkeit („Erwartungswert“)
- Auswirkung („Schadenskoeffizient“)
- Zeitrahmen
- Behandlungsmöglichkeit
- Kopplung



$$\text{Risikofaktor} = \text{Erwartungswert} * \text{Schadenskoeffizient}$$

Beispiel/Übung: Risikofaktor für Risiken im LEGO-Projekt

Ziel – Die 10 wichtigsten Risiken bei Softwareprojekten

Top 10-Risikoelemente			
	1980er Jahre [B. Boehm]	1990er Jahre [B. Boehm]	21. Jhdt. [Pare et al., 2008]
1	personelle Defizite	personelle Defizite	Fehlen von Projekt-Champions
2	unrealistische Termin- und Kostenvorgaben	unrealistische Termin- und Kostenvorgaben, ungenügende Beachtung des Prozesses	Fehlende Unterstützung des oberen Managements
3	Entwicklung falscher Produkteigenschaften	Defizite bei zugekauften Komponenten (COTS)	Schlecht verstandener Systemnutzen
4	schlecht gestaltete Benutzerschnittstelle	falsch verstandene Produkteigenschaften	Zweideutigkeiten im Projekt
5	„Vergolden“ (Realisieren unnötiger Eigenschaften)	schlecht gestaltete Benutzerschnittstelle	Abweichen des Systems von lokalen Praktiken und Prozessen
6	schleichende Änderungen der Funktionalitäten	schlechte Architektur, Performanz, Qualität allgemein	Politische Spielereien oder Konflikte
7	Defizite bei zugekauften Komponenten	Entwicklung falscher Produkteigenschaften	Fehlen von erworbenem Wissen oder Fähigkeiten
8	Defizite bei extern vergebenen Aufgaben	Aufbau auf oder Einbeziehung von Legacy-Software	Personelle Änderungen im Team
9	(Echt-)Zeitperformanz	Defizite bei extern vergebenen Aufgaben	Instabilität der Organisation
10	Überfordern der Technologie	Überfordern der Technologie	Ungenügende Ressourcen

Beispiel/Übung: Behandlung der Risiken im LEGO-Projekt

Risikobehandlung Aufgaben

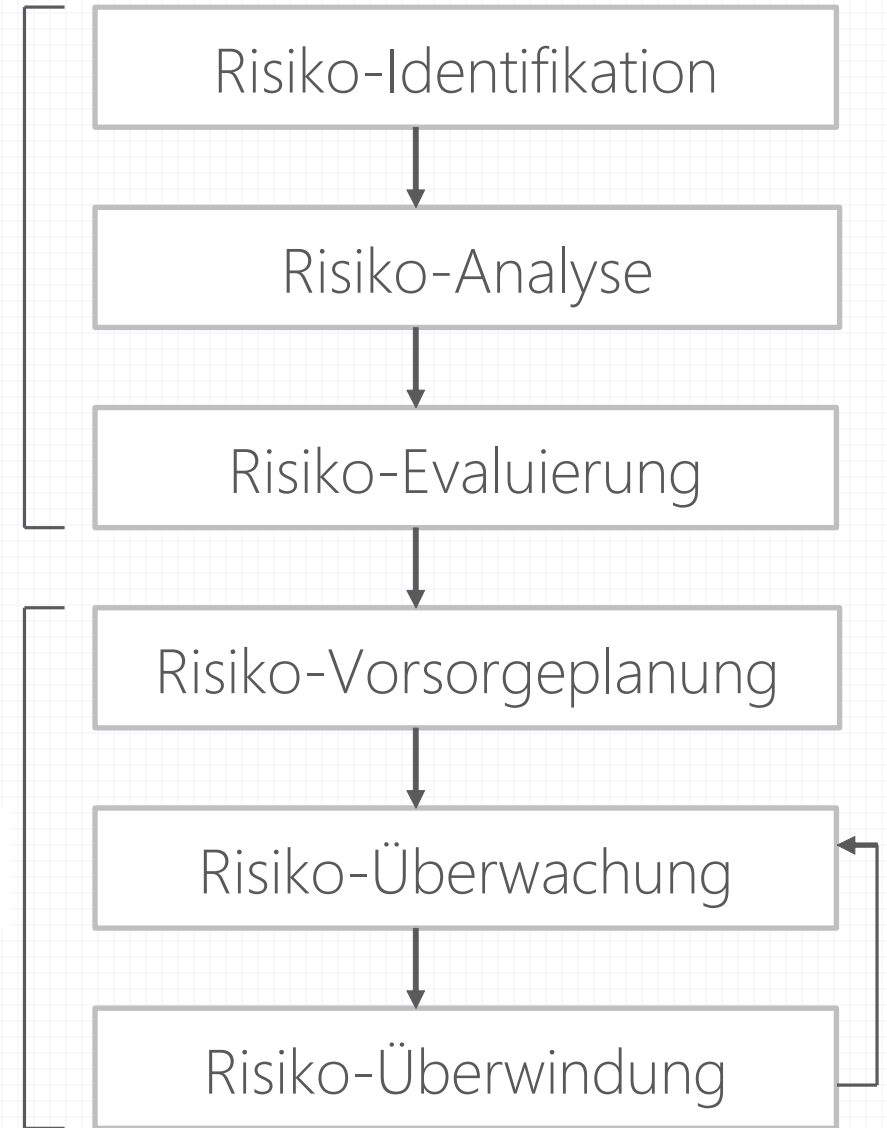
Risikobehandlung – Aufgaben



(Grafik: www.safetyhealthtraining.com)

Risiko-Bewertung

Risiko-Beherrschung



Aufgaben – Risiko-Identifikation

Ermittlung der relevanten projektspezifischen **Risikokriterien**

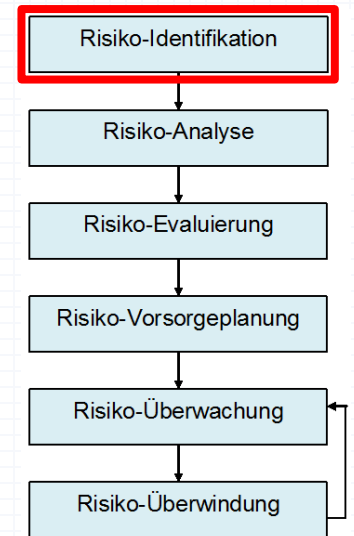
Quellen:

- Analysebericht, Lastenheft, Projektplan
- "lessons learned" aus ähnlichen Projekten
- unsicher abschätzbare Attribute, ungenaue Schätzwerte
- "intelligent" diskutieren

Vorgehen:

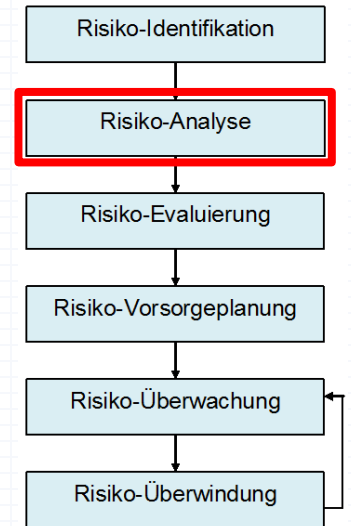
- **Bottom-up:** Risikonennung durch (alle) Mitarbeiter; führt zu langen Listen, hoher Konsolidierungsaufwand!
- **Top-down:** Risikoermittlung aus der Bilanz und den Unternehmenskennzahlen; dabei wird leicht Wichtiges übersehen!

Oft wird nicht angegeben, wie unsicher die Angaben in Dokumenten sind!



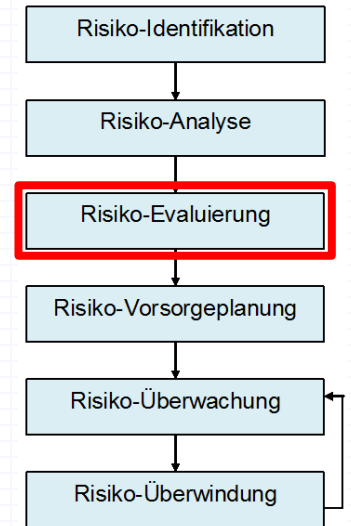
Aufgaben – Risiko-Analyse

- Ermittlung der Schadenswahrscheinlichkeit und des potenziellen Schadensausmaßes (+ Kopplungen)
- durch mehrere Mitglieder in einem Treffen
- am besten quantitativ



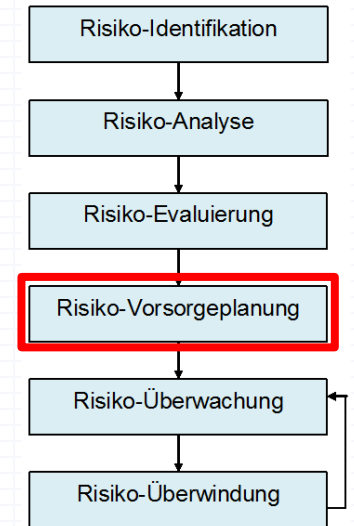
Aufgaben – Risiko-Evaluierung

- Reihung der Risikoelemente entsprechend ihres Projekteinflusses (Risikofaktor!, Hausverstand anwenden)
- Entscheidend ist das Vertrauen in die Zahlen!
- Ergebnis: „watch list“ (Top-n-Liste)



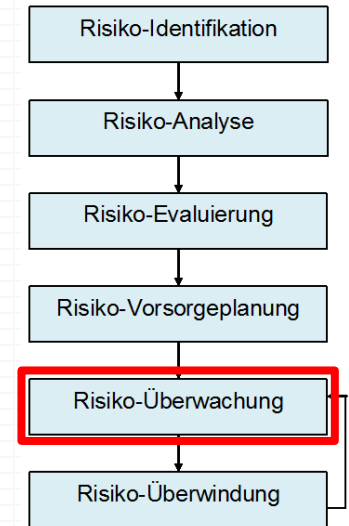
Aufgaben – Risiko-Vorsorgeplanung

- Festlegung eines Aktivitätenplans
- für jedes behandelnswerte Risiko



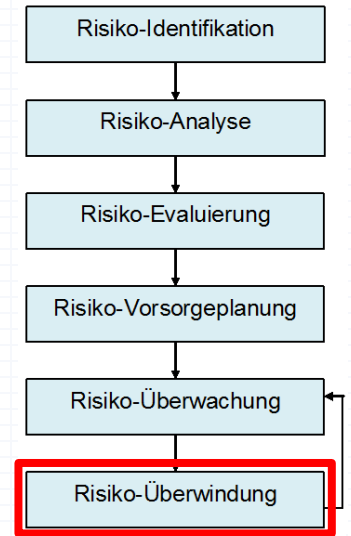
Aufgaben – Risiko-Überwachung

- Überprüfen der Risiken und Vorsorgepläne auf notwendige Aktivitäten und Planadaptierungen
- periodisch und bei Anlass
- Oft wird nicht rechtzeitig eingestanden, dass ein Risiko zu einem Problem wird!



Aufgaben – Risiko-Überwindung

- Anwenden der im Vorsorgeplan festgelegten Technik der Risikobehandlung
- Auftraggeber mit einbeziehen



Risikobehandlung Techniken

Techniken – Abschätzen des Risikoverhaltens

Risikoverhalten von Auftraggeber und Auftragnehmer

(sind risikofreudig, risikoindifferent oder risikoscheu)

Risikoverhalten bestimmt die Strategie der Risikomitigation

Risikomitigation = Risikobehandlung

(im engeren Sinn „Risikominderung“;
to mitigate = mindern; aber: nicht alle
Strategien verringern das Risiko!)



Beispiel/Übung: persönliches Risikoverhalten vs. Gruppe im LEGO-Projekt

Techniken – Strategien der Risikomitigation

- **Risiko-Vermeidung:** Elimination eines Risikos durch Wahl eines alternativen Vorgehens (erhöht oft Risiko in einem anderen Bereich)
- **Risiko-Reduktion:** Verringerung des Risikos nach genauer Untersuchung der Risikoursachen (evtl. durch Aneignung zusätzlichen Wissens)
- **Risiko-Annahme:** bewusste Entscheidung, die Konsequenzen im Fall eines Problems zu tragen (schriftlich begründen und unterweisen: Warnung, Instruktion, Ausbildung)
- **Risiko-Übertragung:** Transfer des Risikos auf andere Verantwortungsbereiche (inkl. Zuständigkeit für Problemlösung)

Beispiel/Übung: Risikomitigation im LEGO-Projekt

- Risiko-Vermeidung:
- Risiko-Reduktion:
- Risiko-Annahme:
- Risiko-Übertragung:

Techniken – Mitigation der wichtigsten Risikoelemente

	Risikoelement	Behandlung (Beispiel)
1	personelle Defizite	gutes Personal vertraglich binden
2	unrealistische Termin- und Kostenvorgaben, ungenügende Beachtung des Prozesses	Entwicklung inkrementell durchführen
3	Defizite bei zugekauften Komponenten (COTS)	Qualifikationstests institutionalisieren
4	falsch verstandene Produkteigenschaften	Benutzerdokumentation früh liefern
5	schlecht gestaltete Benutzerschnittstelle	Prototypen erstellen
6	schlechte Architektur, Performanz, Qualität allgemein	Systemrahmen verwenden
7	Entwicklung falscher Produkteigenschaften	Hemmschwelle des AG erhöhen
8	Aufbau auf oder Einbeziehung von Legacy-Software	Designmuster anwenden
9	Defizite bei extern vergebenen Aufgaben	Zwischenergebnisse reviewen
10	Überfordern der Technologie	externe Peers einbeziehen

Techniken – Verwenden von Standardprodukten

Standardprodukte ("Commercial-off-the-Shelf"-Produkte – COTS) können ebenfalls Risiken reduzieren.

Vorteile:

- + sofort verfügbar, kalkulierbar
- + reife Technologie, umfangreiche Unterstützung
- + plattformunabhängig/-übergreifend
- + kein Wartungspersonal nötig

Nachteile:

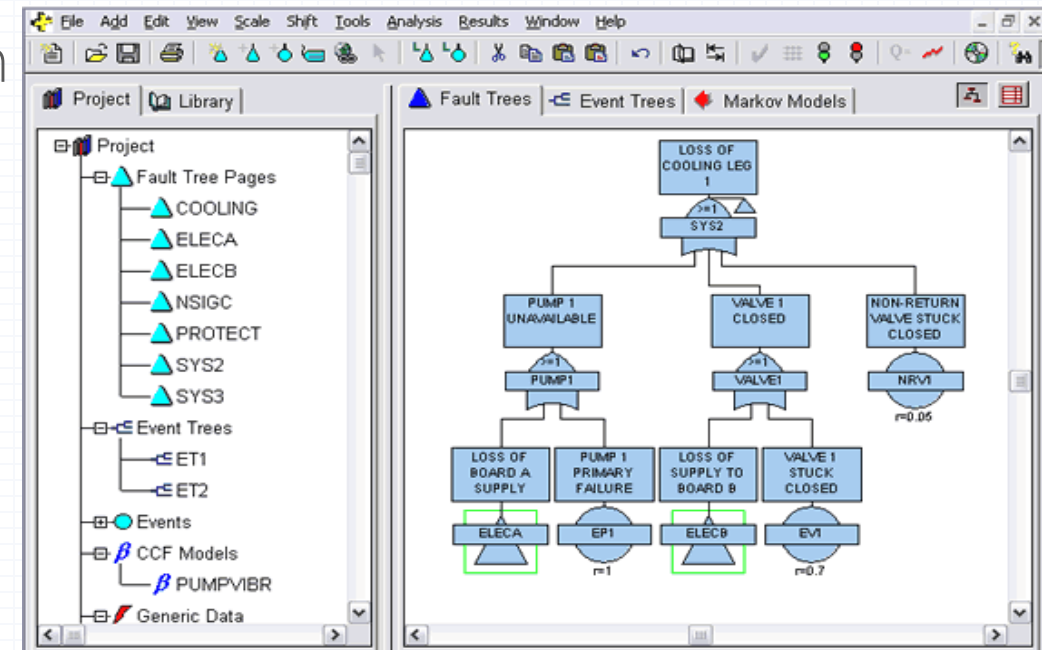
- Abhängigkeit von Zulieferer; Lizenzgebühren zu Beginn
- nicht optimale Ausnutzung des Zielsystems
- Beschränkungen (benötigter) Funktionalität
- schwer skalierbar → Produkt "immer" groß
- oft inkompatibel zu anderen zugekauften Komponenten

→ Entscheidung für oder gegen COTS immer **schriftlich** begründen!

Techniken – Fehlerbaumanalyse (FTA)

Fault-Tree Analysis (FTA): [nach: EN ISO 14971:2019; Details: IEC 61025:2006]

- **Ziel:** Einschätzung der Fehlerwahrscheinlichkeiten
- **Zweck:** Systematischer Ansatz zur Gefährdungsanalyse
- **Fragestellung:** deduktiv („Was verursacht...?“)
- **Vorgehen:** Postulierung einer unerwünschten Hauptfolge („Top Event“), rekursive Ursachensuche auf der jeweils nächst niedrigeren Ebene bis zu den „Blackbox“-Komponenten
- **Darstellung:** als Baum; Fehlerkombination mittels UND/ODER



Techniken – Fehler-Möglichkeiten- und -Einfluss-Analyse (FMEA) (I)

Failure Mode and Effects Analysis (FMEA): [nach: EN ISO 14971:2019; Details: IEC 60812:2006]

- **Ziel:** Einschätzung des Schadensausmaßes
- **Zweck:** Systematischer Ansatz zur Untersuchung und Bewertung der Auswirkungen einzelner Fehler („System-FMEA“); auch für Prozesse („Prozess-FMEA“), Endanwender-Verhalten („Anwendungs-FMEA“) etc.
- **Fragestellung:** induktiv („Was geschieht, wenn...?“);
wenn kein Fehler erkannt: „Sabotage-Methode“
- **Vorgehen:** Untersuchung jeweils einer Komponente zu einem Zeitpunkt, Verfolgung der Auswirkungen rekursiv auf der jeweils nächsthöheren Ebene
- **Darstellung:** als Tabelle

Techniken – Fehler-Möglichkeiten- und -Einfluss-Analyse (FMEA) (III)

Beispiel:

Fehlermöglichkeits- und -einflussanalyse									
Konstruktions-FMEA ☐ Prozeß-FMEA ☐ System-FMEA ☐									
Teil-Bezeichnung		Teil-Nummer		Modell / System / Fertigung		Entstellt durch (Name/Rbt.)		Überarbeitet Datum	
Bestätigung durch betroffene Anwendungen und/ oder Lieferant		Name / Abteilung / Lieferant / Telefon		Name / Abteilung / Lieferant / Telefon		Entstellt durch (Name/Rbt.)		Überarbeitet Datum	
Konstruktionskomponente Prozeßschritt Systemkomponente	Fehler-Nr.	Mögliche Fehler			Derzeitiger Zustand			Verbesserter Zustand	
		Art	Auswirkung	Ursache	Kontrolle Maßnahmen	Aufwand Bedeutung Entdeckung RPZ	Empfohlene Abstellmaßnahmen	Verantwortlichkeit Zuständigkeit	Getroffene Maßnahmen
Fehleranalyse									
Risiko- beurteilung									
Lösungen, Maßnahmen									
Ergebnis- beurteilung									
6 8 13 15 7 9 10 11 12 14 16									
Wahrscheinlichkeit der Entdeckung des Fehlers (vor Auslieferung an Kunden)					Wahrscheinlichkeit der Entdeckung des Fehlers (vor Auslieferung an Kunden)				
mäßig = 7 - 8 hoch = 9 - 10					mäßig = 2 - 5 gering = 6 - 8 sehr gering = 9 unwahrscheinlich = 10				

Berechnung der Risikoprioritätszahl (RPZ):

$$RPZ = A * B * E, \text{ wobei}$$

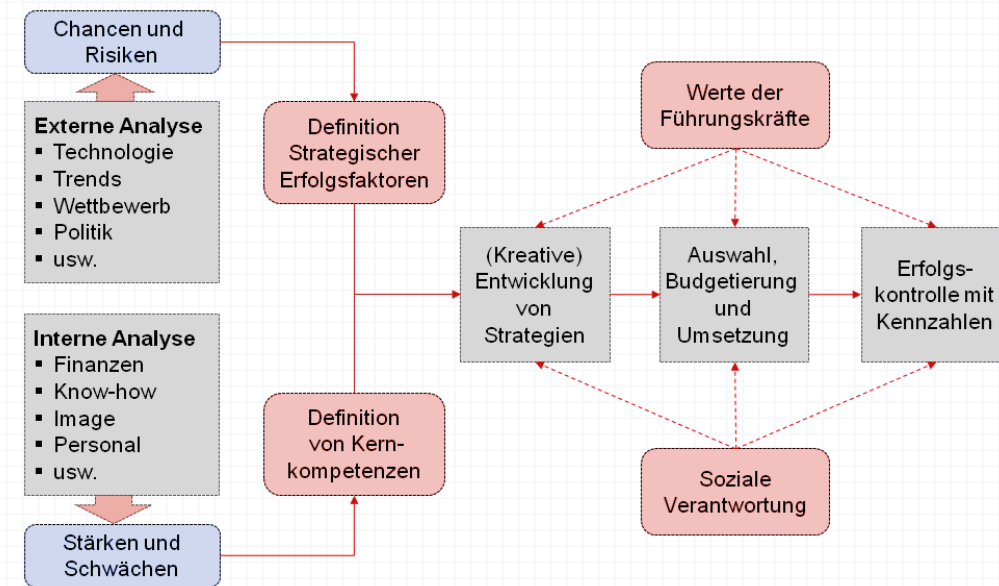
- A = Auftrittswahrscheinlichkeit [1-10],
- B = Bedeutung („Schadensausmaß“) [1-10]
- E = Entdeckungswahrscheinlichkeit [1-10]

(Quelle: „Qualitätsmanagement von A bis Z“, F.G. Kamiske u. J.-P. Brauer, Hanser 1995)

Techniken – Stärken-Schwächen-Chancen-Risiken-Analyse (SWOT)

Strengths-Weaknesses-Opportunities-Threats-Analyse (SWOT)

- **Ziel:** Erarbeitung des Schlüsselpfils eines Unternehmens zur Strategieentwicklung (auch im Bereich Risiko)
- **Zweck:** Chancen- und Risikenanalyse, um sich der eigenen Stärken und Schwächen bewusst zu werden
- **Entstehung:** entwickelt in den 1960er Jahren an der Harvard Business School
- **Positionierung:** im strategischen Management
- **Darstellung:** als Matrix „externe Analyse“ vs. „interne Analyse“



(Quelle: W. Petz, THM Business School)

Risikobehandlung Werkzeuge

Risikobehandlung – Werkzeuge

- eigene (manchmal Web-basierte) **Risikomanagement-Werkzeuge** (z.B. *JPL Defect Detection and Prevention System* des NASA Jet Propulsion Lab)
- Erweiterung von **Projektplanungswerkzeugen** (z.B. *MS Project*)
- Anwendung/Erweiterung von **Qualitätsmanagement-Verfahren** (z.B. *Balanced Scorecard*)
- Planer für alternative Projektverläufe (**Critical Path Analyzer**)
- **Tabellenkalkulationsprogramme**
- "einfache" **Listen**
("Hauptsache schriftlich")



100

(Quelle: H. Russegger, Quality Austria)

Werkzeuge – Risiko-Fieberkurve

Bewertung nach **Checkliste** (z.B. GoDV – Grundsätze ordnungsgemäßer Datenverarbeitung)

Erstellung einer „**Fieberkurve**“:



(Quelle: H. Russegger,
Quality Austria)

Checkliste DV - Datenverarbeitung

		Regel Die schlechteste Risikobewertung der Fragebeurteilung wird in die Übersichts-Matrix übertragen				
DV 01	Gibt es zur Umsetzung und Einhaltung der IT Security Policy und der definierten festgelegten Maßnahmen klare Regelungen?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 02	Sind DV gestützte Geschäftsprozesse identifiziert und ist die Kritikalität dieser Prozesse erhoben?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 03	Erlagt darauf aufbauend eine regelmäßige Klassifizierung der zu schützenden Systeme, Anwendungen und Daten und bildet diese Klassifizierung die Basis für weitere Sicherheits-/Schutzmaßnahmen?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 04	Werden Sicherheitsaspekte organisatorisch berücksichtigt, z.B. durch einen unabhängigen Verantwortlichen für die Informationssicherheit mit Zuständigkeit für Planung, Durchführung und Kontrolle der Sicherheitsmaßnahmen?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 05	Sind DV-Sicherheitsbereiche definiert und wurden ausreichende physische Schutzmaßnahmen getroffen?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 06	Wird die Aufwahrung der Nichtverfügbarkeit der DV ermittelt und bewertet (insbesondere für kritische Prozesse der Produktion und der Administration)?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 07	Existiert ein Notaktionsplan zur Bewältigung eines geplannten/geplanten Rechenzentrum- bzw. Systemnetzwerk-ausfalls/-störungs bzw. für Ausfälle/Störungen der EDV in den Produktionsbereichen?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 08	Wird durch nach Ausfallzeiten (wie zum Beispiel: Ausfall / Stillstand für 1 Stunde, bis zu 1 Tag, > 1 Tag) unterschieden?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 09	Besteht ein ausreichender Versicherungsschutz gegen Risiken, die trotz organisatorischer und technischer Maßnahmen bestehen	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 10	Existiert ein abgestimmtes Konzept von Schutzmaßnahmen gegen Datenverlust, unberechtigte Zugriffe und missbräuchliche Datenveränderung (insbesondere von Kommunikationssystemen, Datenbanksystemen, standard- und Individualsoftware)?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 11	Existieren dokumentierte Verfahren zur Datensicherung und werden sie angewendet?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 12	Werden Verfahren zur Entwicklung und zum Einsatz der Programme ordnungsgemäß eingehalten?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 13	Sind Regelungen zur Entwicklung von Anwendersystemen und deren Wartung auch unter dem Gesichtspunkt der Datenverfügbarkeit und -integrität festgelegt worden?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 14	Werden die Anwendungsprogramme vor ihrem Einsatz sorgfältig zusammen mit der Fachabteilung getestet?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 15	Wird für sensible Tätigkeiten konsequent das Prinzip der Funktionsentrennung angewendet?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 16	Stellt die DV-Organisation sicher, dass die Hardware- und Kommunikationsausrüstung Sicherheitsaspekte angemessen berücksichtigt?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 17	Gibt es Regelungen für die Systemprogrammierung/-steuerung (z.B. Funktionsentrennung, Anwendungsprogrammierung und Produktionsbetrieb, Berechtigungskonzept)?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 18	Besteht ein angemessenes Zugriffsschutzmanagement zum Schutz der Daten vor unbefugtem Zugriff/Manipulation?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 19	Beinhaltet das Zugriffsschutzmanagement Funktionsentrennung und werden bestehende Zugriffsberechtigungen einem Review unterzogen?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 20	Sind alle relevanten IT Anlagen und -Bestände inventarisiert?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 21	Sind IT-Sicherheitsanforderungen bei Zugriff auf Systeme und Daten durch Dritte bzw. bei Nutzung externer Dienste und bei Outsourcing geregelt?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 22	Beinhaltet Dienstverträge eine Vertraulichkeitsvereinbarung und wird Datenmissbrauch darin geregelt?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 23	Werden gesetzliche Vorgaben und Anforderungen eingehalten?	nicht relevant	gering	behehrsch	granzwertig	ALARM
DV 24	Wird der korrekte und sichere Betrieb der IT regelmäßig überprüft?	nicht relevant	gering	behehrsch	granzwertig	ALARM

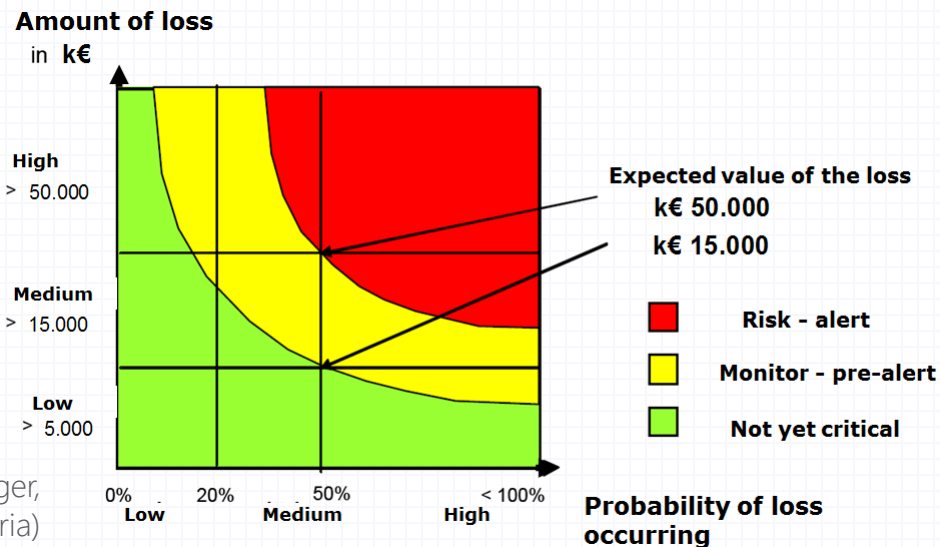
(„GoDV-Handbuch“,
Beck Verlag 2007)

Werkzeuge – Risiko-Hitzekarte

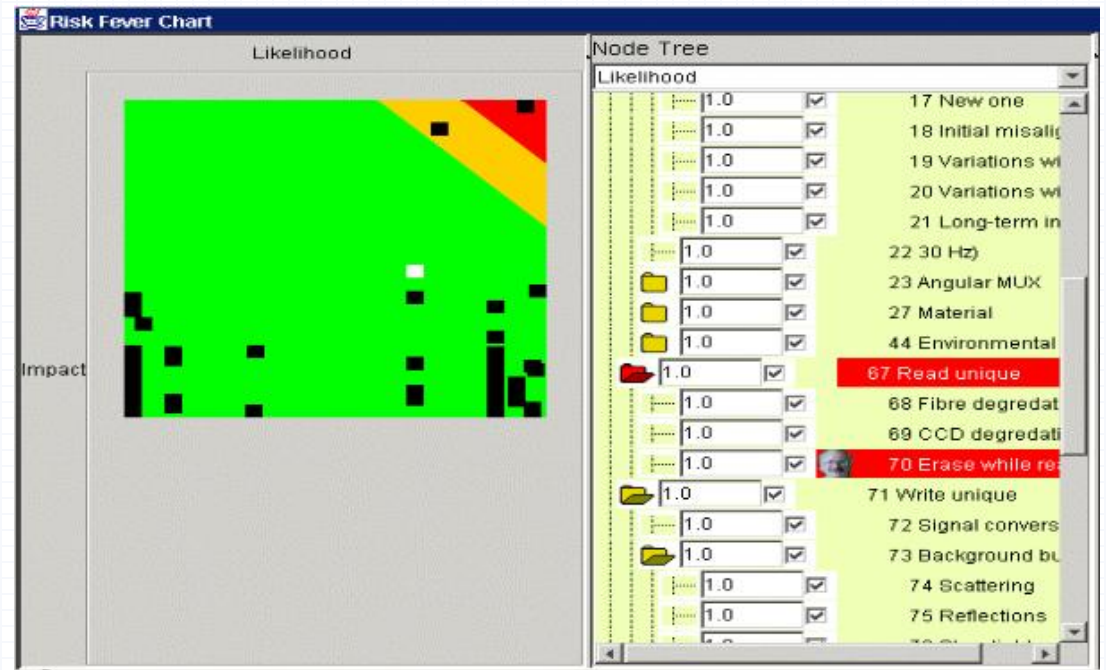
Risiko-Portfolioanalyse mittels Risk Heat/Fever Chart:

visualisiert Risikoelemente in einer 2D-Karte „Wahrscheinlichkeit vs. Schadensausmaß“

Beispiele:



(Quelle: H. Russegger, Quality Austria)



(NASA JPL DDP Tool,
<http://ddptool.jpl.nasa.gov> – dzt. offline)

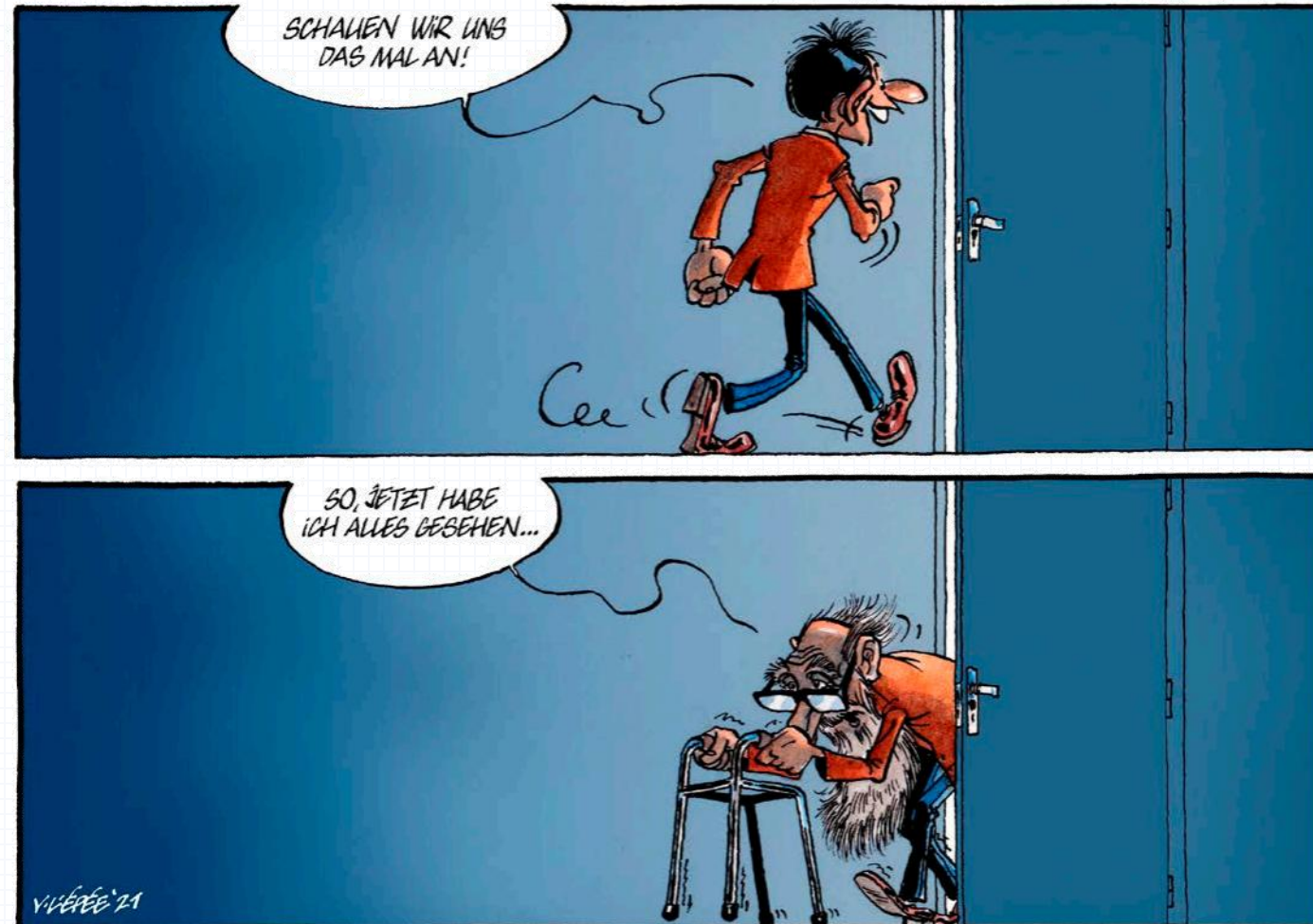
Risikobehandlung Ergebnisse

Risikobehandlung – Ergebnisse

Ergebnisse

- Risiko-Top-N-Liste
- Risiko-Vorsorgeplan

(Cartoon: www.babs.admin.ch)



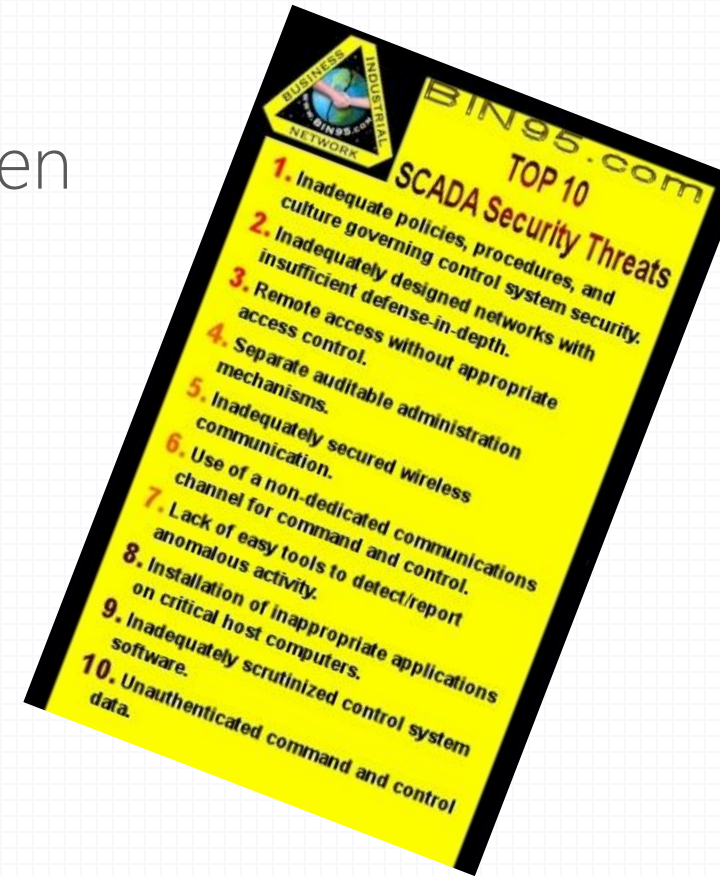
Ergebnisse – Risiko-Top-N-Liste

Top-N-Liste der Risikoverfolgung: Liste der N wichtigsten identifizieren Risikoelemente, nach Risikofaktor gereiht

Ein **Eintrag** enthält:

- Beschreibung des Risikoelements
- Risikofaktor
- aktuellen Rang
- vorherigen Rang
- Dauer (wie lange in der Liste)
- Fortschritt bei der Behandlung

Top-N-Liste regelmäßig (und im Anlassfall) **aktualisieren**, vor allem neue und aufsteigende Risiken rasch behandeln!



Beispiel/Übung: Erstellen einer Risiko-Top-5-Liste für das LEGO-Projekt

-> Übung!

Ergebnisse – Risiko-Vorsorgeplan (I)

Der **Risiko-Vorsorgeplan** legt die Vorgehensweise zur Risikoüberwachung und -überwindung fest.

Er enthält:

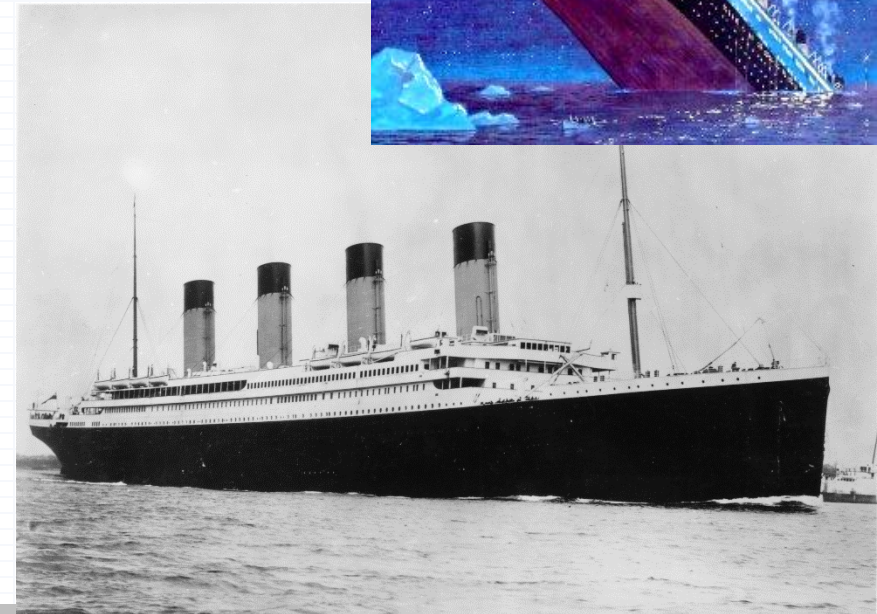
- zuständiges Personal
- Risiko-Bewertungsprozess
- Risiko-Überwachungsprozess
- Aktualisierungsvorschriften für Top-N-Liste und Vorsorgeplan selbst
- Trigger für außerplanmäßige Aktualisierungen



Ergebnisse – Risiko-Vorsorgeplan (II)

Der **Risiko-Vorsorgeplan** enthält für **jedes relevante Risikoelement**:

- Beschreibung des Risikoelementes mit Annahmen und Beschränkungen
- Schadenswahrscheinlichkeit und potenzielles Schadensausmaß
- Risiko-Kopplung
- Alternativen im Projektplan
- empfohlene Behandlungstechnik mit Arbeitsschritten
- notwendige Einbeziehung des Auftraggebers
- Auswirkungen auf den Projektplan
- Trigger zur Erkennung des Eintretens des Problems
- Kriterien zur Risikoelimination



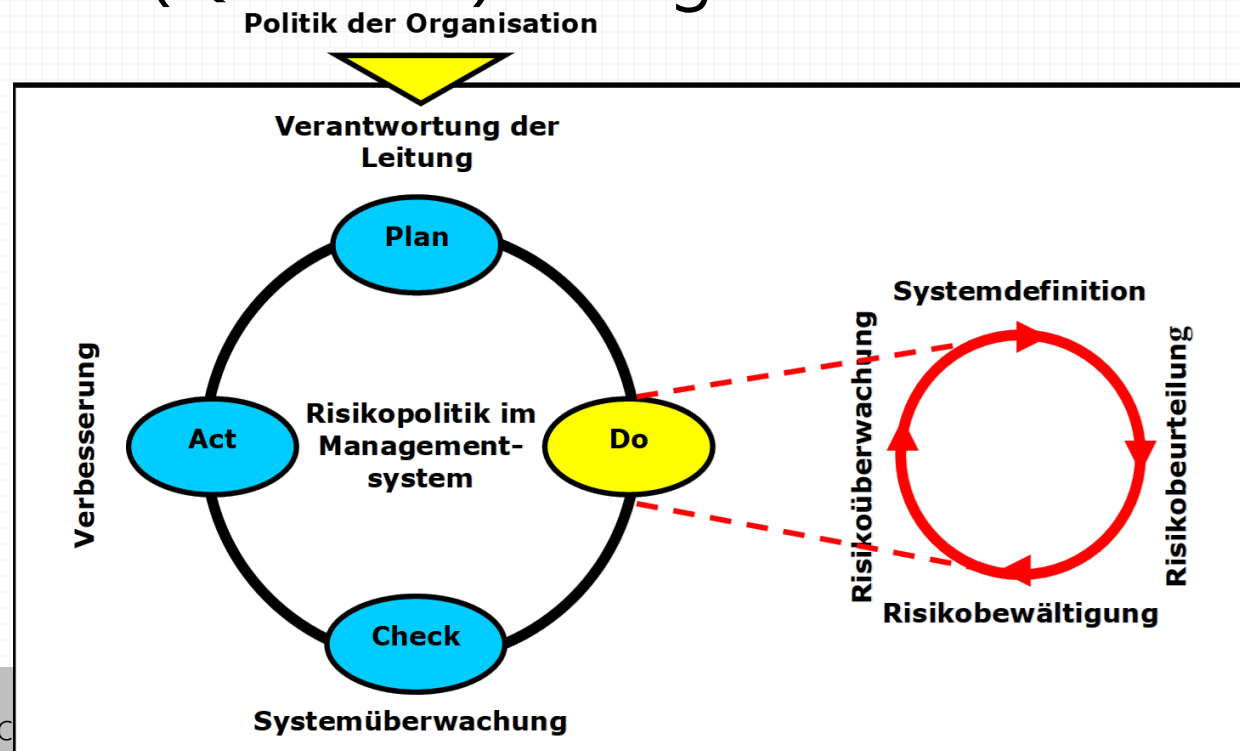
(Bilder: techpinions.com & americanhistory.si.edu)

Risikobehandlung als strategische Aufgabe: Risikomanagement

Risikomanagement

Risikomanagement = Risikoplanung + Risikobehandlung + Monitoring, Review & Verbesserung der Risikobehandlung
(eigentl. Risikoentwicklung – Begriff aber wenig gebräuchlich)

Integration in das (Qualitäts-)Management des Unternehmens:



[gemäß ONR 49000:2014;
Darstellung nach H. Russegger,
Quality Austria]

Risikomanagement – Motivation

Risikomanagement ist eine Führungsaufgabe!

- zur **Sicherstellung** der Zielerreichung von Organisationen
- zur **Umsetzung** von Sicherheitsanforderungen
- zum rechtzeitigen **Erkennen** (negativer) externe Einflüsse
- zur **Absicherung** externer Erwartungen



Risikomanagement – Basis Risikopolitik (I)

Die Risikopolitik muss Aussagen über

- die **Ziele**,
- die **Strategien** und
- die **Ressourcen** für den Umgang mit Risiken

in einer Organisation enthalten!

Weiters sollen in der Risikopolitik Aussagen über

- die **Faktoren**, die den **Erfolg** und die Erfolgspotenziale der Organisation bedrohen und
- die **Kernrisiken**, die die Organisation bewusst eingeht, enthalten sein!



Quelle : Caniu GRC Methoden



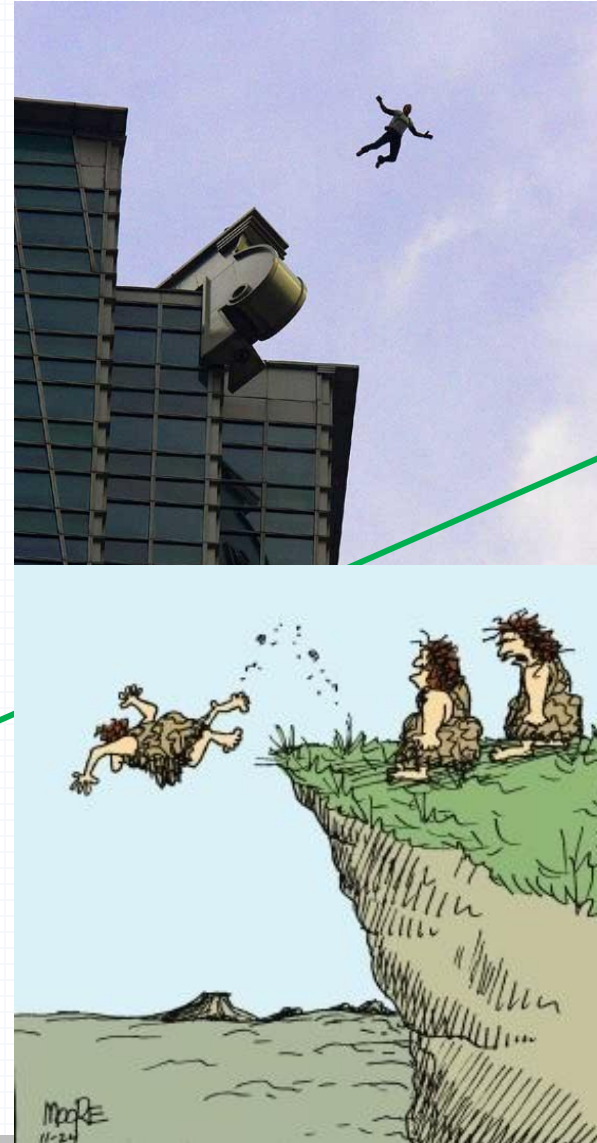
Risikomanagement – Basis Risikopolitik (II)

Risiko versus Sicherheit:

Sicherheit (dt.) =
Security + Safety (en.):

- Security = Systemsicherheit,
- Safety = Betriebssicherheit

$$\text{Sicherheit} = \frac{\text{Kompetenz}}{\text{Komplexität}}$$



Definition des
Risikomanagement-
systems

Etablierung der
Risikomanagement-
Governance

Initiale
Risikoanalyse

Auswahl & Einführung
IT-Unterstützung

Optimierung des
Risikomanagement-
systems

Quelle: Caniu GRC Methoden

Risikomanagement – Prozess

Situierung des Risikomanagements: [ISO 31000:2018, §5.1]

- als integraler Teil des Managements,
- eingebettet in die Unternehmenskultur und -praktiken, und
- maßgeschneidert auf die Geschäftsprozesse der Organisation.



Risikomanagement – Stellen (I)

Risikobeauftragter (Risk Representative):

verantwortlich für das Risikomanagement;
benannt von der obersten Leitung

Aufgaben:

- Benennung von Risikoeigner und Risikomanager
- Sicherstellung der operativen Umsetzung der Risikopolitik inkl. Kommunikation und Ressourcen
- Koordination der Aufgaben des Risikomanagementprozesses
- Überwachung des Risikomanagementsystems (auf Eignung, Effektivität, Effizienz)

(Zusammenfassung aus: ISO 31000:2018 „Risk Management – Principles and Guidelines“)

Risikomanagement – Stellen (II)

Risikoeigner (Risk Owner):

Führungskraft, kann Risiken beeinflussen;
verantwortlich für seine/ihre Risiken

Risikomanager (Risk Manager):

kann Risiko nicht selbstständig beeinflussen;
nicht für Risiko, aber für Durchführung des Risikomanagements
verantwortlich

(Zusammenfassung aus: ISO 31000:2018 „Risk Management – Principles and Guidelines“)

PROJEKT ENGINEERING

Risikobehandlung

Herwig Mayr

Fakultät für Informatik, Kommunikation und Medien
Fachhochschule OÖ, Hagenberg